Network Analysis - Ransomware

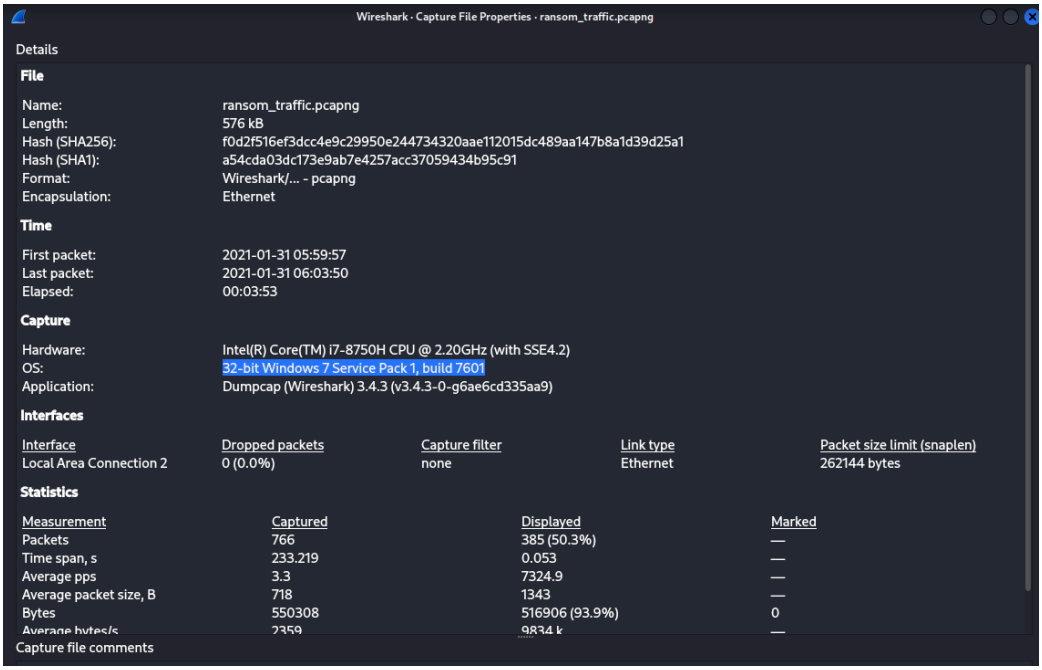
1. Kịch bản

- Công ty ABC chuẩn bị hồ sơ dự thầu nhưng đã gặp ransom và phiên bản final của hồ sơ bị mã hóa.
- Có: network traffic, ransom note (thư đòi tiền chuộc), tài liệu đã mã hóa

2. Write-up

1. What is the operating system of the host from which the network traffic was captured? (Look at Capture File Properties, copy the details exactly)

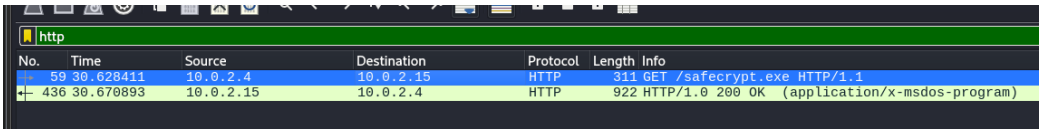
- File PCAPNG lưu metadata chi tiết hơn file PCAP, chứa các thông tin như OS của máy thực hiện capture



2. What is the full URL from which the ransomware executable was downloaded?

- Sau khi có truy cập ban đầu, nạn nhân gửi HTTP GET tới máy attacker (trong cùng mạng với nạn nhân) và tải payload

- Do IP là private → file được tải nằm trong máy attacker chứ không tải từ internet
- http://10.0.2.15:8000/safecrypt.exe

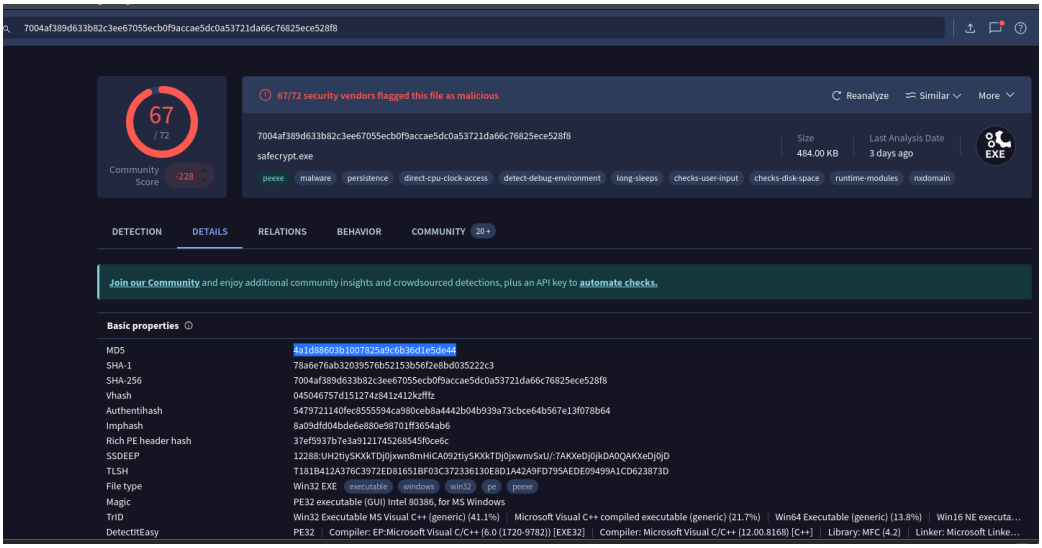


3. Name the ransomware executable file?

- safecrypt.exe: nó chính là file xuất hiện trong yêu cầu HTTP GET ở câu trước đó

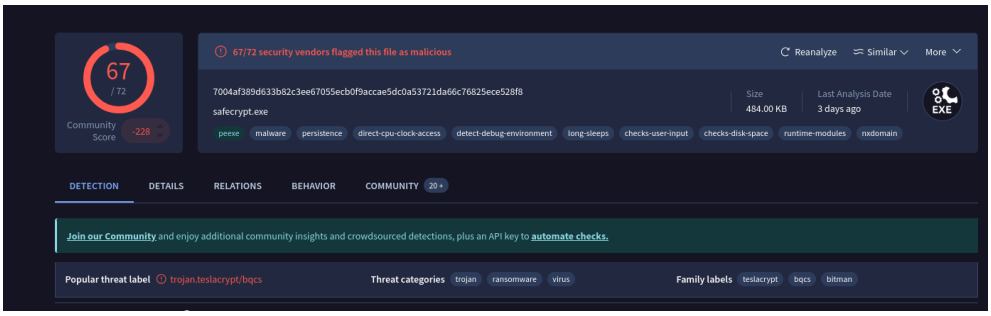
4. What is the MD5 hash of the ransomware?

- Export file sau đó đưa lên virustotal để lấy thông tin



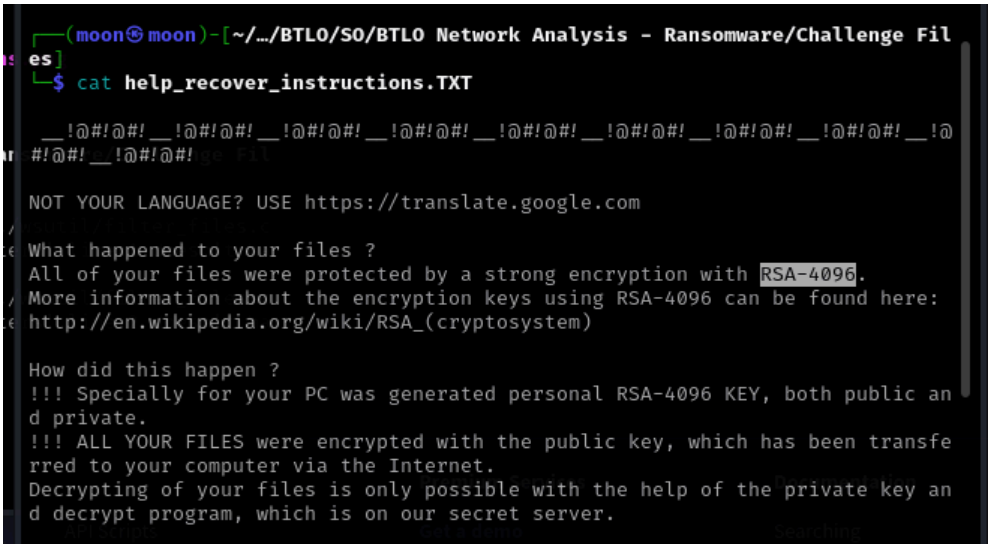
5. What is the name of the ransomware?

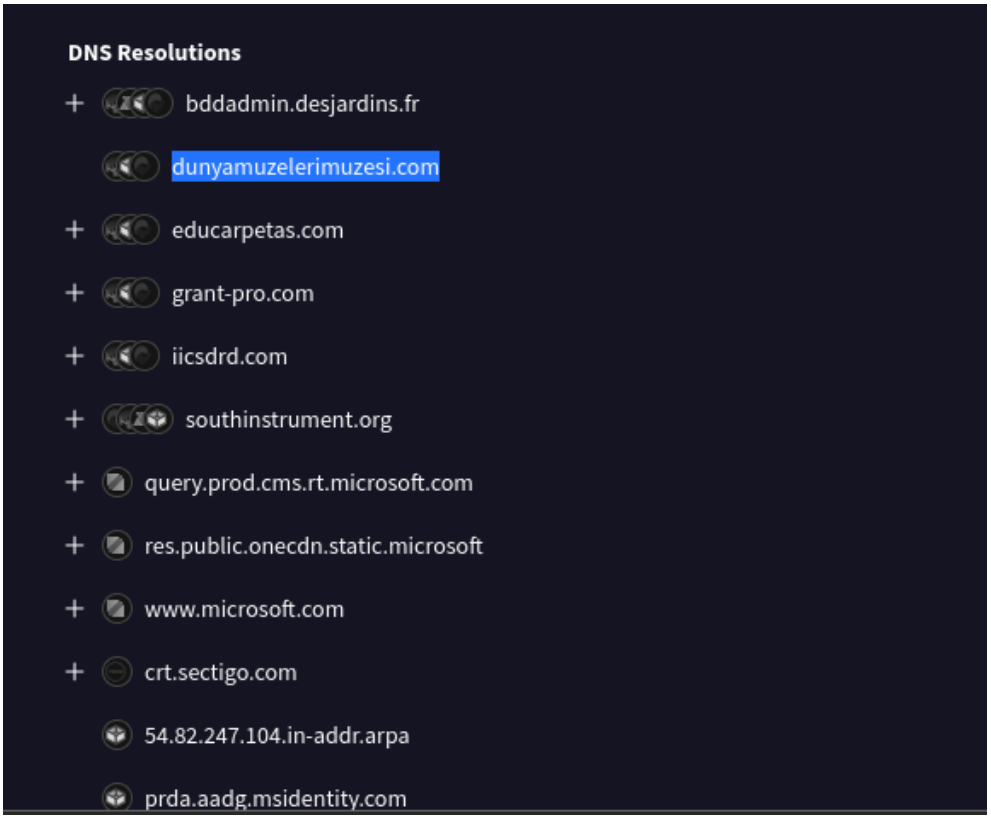
- Từ label cho thấy
  - Loại malware: trojan → cách hoạt động giống trojan
  - Thuộc họ teslacrypt - một họ ransom nổi tiếng



6. What is the encryption algorithm used by the ransomware, according to the ransom note?

- Thông tin cho biết dữ liệu bị mã hóa bởi RSA-4096, với khóa công khai gửi từ internet đến và yêu cầu người dùng mua Bitcoin để giải mã file.

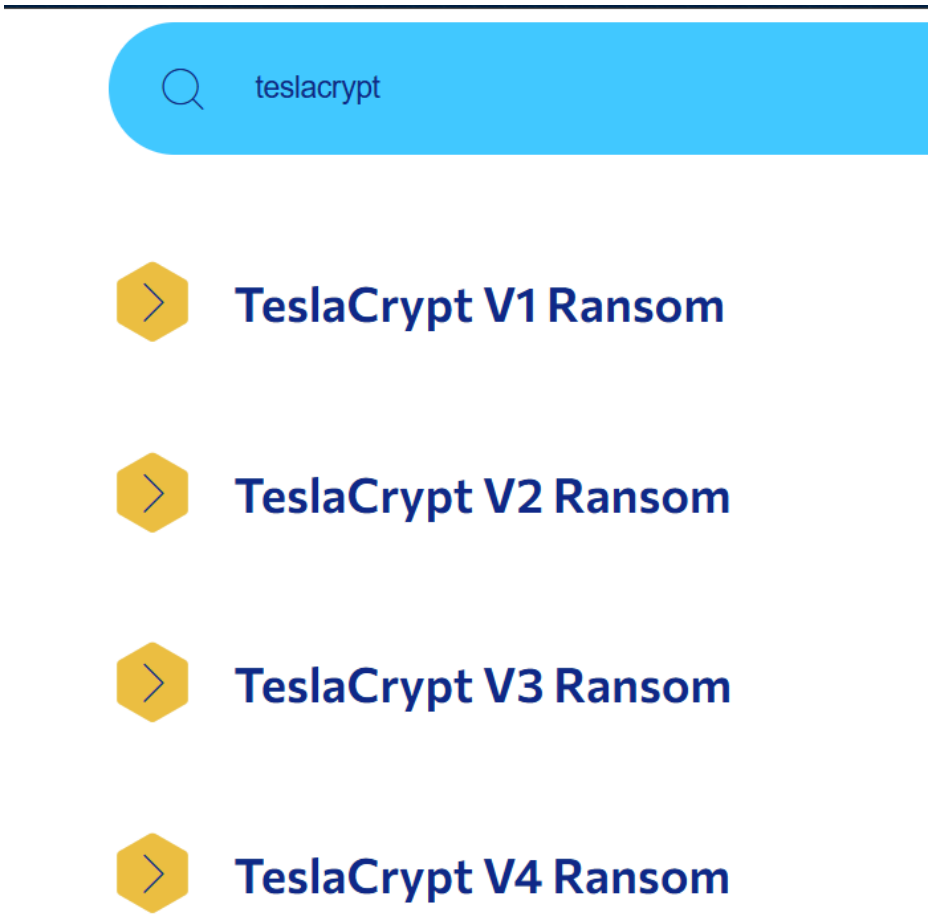

┌──(moon㉿moon)-[~/…/BTLO/SO/BTLO Network Analysis - Ransomware/Challenge Files]
└─$ cat help_recover_instructions.TXT
__!@#!@#!__!@#!@#!__!@#!@#!



8. Decrypt the Tender document and submit the flag

- Các bước xử lý khi gặp ransomware
  - Cô lập máy
    - Ngăn C2, mã hóa file mới, lây lan trong LAN
  - Xác định ransomware family và tìm xem có decrypt tool không
    - Tìm tool: https://www.nomoreransom.org/
  - Sao lưu
    - File bị mã hóa, ransom note, key.dat (nếu có)
  - Loại bỏ ransomware khỏi hệ thống
    - Quét bằng công cụ và kill persistence
    - Không decrypt khi malware đang chạy
  - Decrypt thử trên 1 file → nếu kết quả ok thì mới decrypt toàn bộ
- Thực hiện decrypt

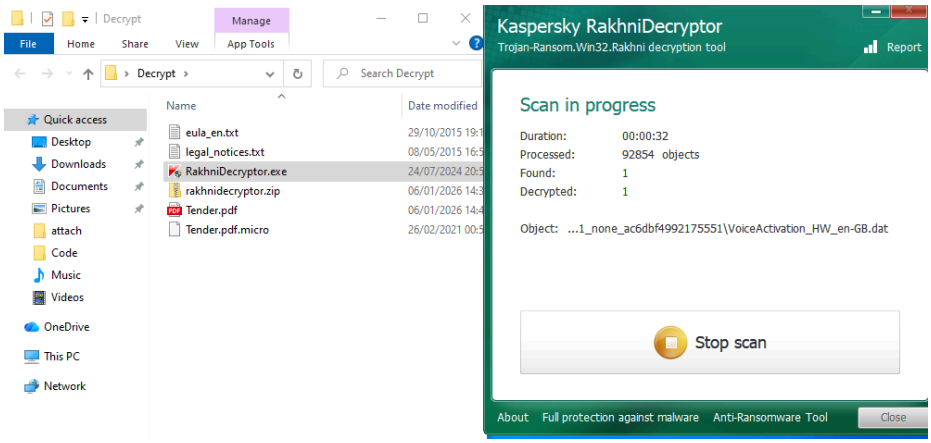
- Tìm kiếm công cụ → có 4 version



- Chọn tool V3 vì file mã hóa có đuôi .micro

Ransomware	File name and extension
CryptXXX V1, V2, V3*	{original file name}.crypt, cryp1, crypz, or 5 hexadecimal characters
CryptXXX V4, V5	{MD5 Hash}.5 hexadecimal characters
Crysis	.{id}.{email address}.xtbl, crypt
TeslaCrypt V1**	{original file name}.ECC
TeslaCrypt V2**	{original file name}.VVV, CCC, ZZZ, AAA, ABC, XYZ
TeslaCrypt V3	{original file name}.XXX or TTT or MP3 or MICRO
TeslaCrypt V4	File name and extension are unchanged

- Cài công cụ về và chạy giải mã



- Kết quả thu được flag

BTLO-T3nd3r-Fl@g

3. Kết luận

- Máy attacker nằm trong cùng mạng LAN với máy nạn nhân. Sau khi lấy được quyền truy cập ban đầu, từ máy nạn nhân tạo HTTP GET request tới máy attacker để tải file malware về
- Sau khi xem xét, phát hiện malware này là ransomware họ teslacrypt, thực hiện C2 ra ngoài Internet để lấy public key mã hóa file trong thuật toán RSA-4096
- Nhờ đuôi file mã hóa là .micro, xác nhận file thuộc họ teslacrypt V3. Tải công cụ decrypt cho tetlacrypt V3 và giải mã file thu được văn bản ban đầu.